デジタルツイン環境における医療情報共有システムの安全性評価

林 瑞貴[1,a)]　江村 恵太[1,2,b)]

概要：Gao ら (IEEE IoT Journal 2025) は ID ベース暗号, 公開鍵検索可能暗号, ブロックチェーン技術を用いたデジタルツイン環境における医療情報共有システムを提案した. 本システムは, 電子カルテ等の医療データを暗号化しつつ, どのような病名や疾患で検索を行っているのかという情報を秘匿したまま検索する機能の実現を目的に提案されている. 本論文では, Gao らの医療情報共有システムにて, 他人の医療データが閲覧可能であることを示す. 提案攻撃では, 検索権限の委譲機能を実現するために ID ベース暗号のマスター秘密鍵を全患者で共有していることに着目した. さらに検索サーバがトラップドア (検索クエリ) から検索キーワードの情報を得られることも示す. さらにキーワードと公開情報のみで計算可能なラベルを用いて, 医療データとキーワードの暗号文を保存している IPFS (InterPlanetary File System) のアドレスをブロックチェーンから取得している手順を精査, キーワードそのものを検索サーバに渡していることから, そもそも検索可能暗号を利用する必要がないことも示す. 我々の安全性評価により, 本システムの根本的な再設計が必要であると主張する.

キーワード：医療情報共有システム, ID ベース暗号, 検索可能暗号, デジタルツイン, ブロックチェーン

Security Analysis on a Secure Medical Data Sharing System in Digital Twin Environments

Mizuki Hayashi[1,a)]　Keita Emura[1,2,b)]

Abstract: Gao et al. (IEEE Internet of Things Journal, 2025) proposed a medical information sharing system for digital twin environments that employs identity-based encryption (IBE), public-key encryption with keyword search (PEKS), and blockchain technology. The system aims to provide keyword-search functionality over encrypted data using medical-related keywords. In this paper, we demonstrate that a patient can access the medical data of other patients. Specifically, we point out that the master secret key of the underlying IBE scheme is shared among all patients for the purpose of delegating the search functionality. Furthermore, we show that the cloud server responsible for performing searches over ciphertexts can obtain keyword information from trapdoors. In a medical information sharing system, the medical-related keywords used in searches should remain confidential. Based on our security analysis, we argue that a fundamental redesign of the system is necessary.

Keywords: Secure Medical Data Sharing System, Identity-based encryption, Searchable Encryption, Digital Twin, Blockchain

[1] 金沢大学
Kanazawa University
[2] 産業技術総合研究所
National Institute of Advanced Industrial Science and Technology (AIST)
[a)] mizmiz884knzw@stu.kanazawa-u.ac.jp
[b)] k-emura@se.kanazawa-u.ac.jp

1. はじめに

米国国立標準技術研究所 (NIST: National Institute of Standards and Technology) では, デジタルツインを “A digital twin is a particular type of computer model of a

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

physical system, such as a machine or building, that has the potential for high accuracy, precision, and flexibility to model various aspects of a system." と紹介している.[*1] 医療系論文検索サービス PubMed[*2]において, "digital twin" で検索すると, 2,093 本の論文がヒットした (2026/07/21 現在). さらにここ数年論文数が伸びている. 具体的に 2023 年 365 本, 2024 年 496 本, 2025 年 912 本, 2026 年は 7 月の段階で既に 817 本の論文が出版されている. 以下, 検索時に "Sort by Best Match" にてヒットしたサーベイ論文を引用する. Vallée [8] の論文では, 電子カルテ (EHR: Electronic Health Record), ウェアラブルデバイス, 医療機器などのソースから患者データを収集しリアルタイムにデータを統合, これらデータを機械学習アルゴリズム等で分析することで様々な利点があること, 具体的に患者ケアの向上, 予測分析の実現, 臨床業務の最適化, トレーニングとシミュレーションの促進等を挙げている. Laubenbacher ら [6] は医療用デジタルツイン開発の現状, 特に最も開発が進んでいる腫瘍学 (Oncology) と心臓病学 (Cardiology) における現状について概説すると共に, データ統合やプライバシーにおける課題についても議論している.

医療データには患者の病状などが含まれており, (デジタルツインに限らず) これらデータを電子化して扱うには適切な取り扱いが求められる. 例えば日本においては, 厚生労働省が医療情報システムの安全管理に関するガイドライン[*3]を公開している. このシステム運用編には

- 医療情報が保存されている場合には, 記録媒体に暗号化を施す必要があるほか, 患者等の医療情報を表示や編集できる場合は, その機能を持つアプリの起動にパスワードを設定するなどの措置も必要である.
- 医療情報及び情報機器等の持出しに際しての盗難, 置き忘れ等に対応する措置として, 医療情報や情報機器等に対する暗号化やアクセスパスワードの設定等, 容易に内容を読み取られないようにすること.
- 暗号を用いる場合は, 電子政府推奨暗号の暗号方式を採用すること.

などが記述されている.

研究動機. 我々の知る限り, 医療現場においては通常の暗号や署名等は利用されているものの, これら従来の暗号技術に対して機能が追加・向上される等の優位性を主張する高機能暗号[*4]においては未だ実利用されておらず, 社会実装はこれからという状況である. 高機能暗号は様々な安全性や機能を実現する一方で, 安全性の定義が複雑となり, 適切な運用に向けては様々な課題が想定される. そこで本論文では, 高機能暗号の一種である ID ベース暗号 (IBE: Identity-Based Encryption) [3], [7], [9] や公開鍵検索可能暗号 (PEKS: Public-key Encryption with Keyword Search) [1], [2] を用いた, デジタルツイン環境における医療情報共有システム [4] について安全性評価を行う. Gao らによる本システムは, 電子カルテ等の医療データを暗号化しつつ, 病名などをキーワードとした暗号化データに対するキーワード検索機能の実現を目的に提案されている.

本論文の貢献. 本論文では, Gao らの医療情報共有システムにて, 他人の医療データが閲覧可能であることを示す. 提案攻撃では, (検索権限の委譲機能を実現するために) ID ベース暗号のマスター秘密鍵 msk を全ユーザで共有していることに着目した. 暗号理論研究者視点からは, 任意の ID に対する秘密鍵を生成可能な msk は共有すべきものではなく, その漏洩により IBE による医療データの秘匿が意味を成さないことは明白である. この鍵供託問題が存在するため, 安全性モデルでは攻撃者に msk を与えない. 一方, システムセキュリティ研究者視点からはそのような安全性モデルは自明ではないと考えられる. なお $\alpha \in \mathbb{Z}_p$ をマスター秘密鍵とするという記述もあることから, Waters IBE のマスター秘密鍵を α と想定し, g_2^{α} はマスター秘密鍵ではないと解釈した可能性も考えられる. いずれにせよ, 高機能暗号たる IBE の安全性モデルや方式が (従来の暗号方式と比較して) 複雑であることに起因した IBE の不理解が原因であると考える.

さらに検索を行うクラウドサーバが, トラップドアから検索キーワードの情報を得られることも示す. 医療に関するキーワード検索が想定されている本システムにおいて, どのような病名や疾患で検索を行っているのかという情報は秘匿される必要がある. (後述する) 内部攻撃者 (クラウドサーバ) に対するキーワード推測攻撃耐性を貢献の 1 つとして挙げているにも関わらず, 攻撃者にクラウドサーバの秘密鍵を与える安全性モデルを採用していないことが原因であると考える. なおサーバ秘密鍵の解釈について, 下記「送信者鍵とサーバ鍵について」にて後述する. なおキーワード暗号文は IPFS (InterPlanetary File System) に保存されており, この IPFS のアドレスを得るためにキーワードを用いたラベル ($\mathsf{Label}_w = H_1(\mathsf{PK}_{ID}||w)$, H_1 は衝突困難ハッシュ関数) を利用している. ラベルを用いて IPFS に保存されたキーワード暗号文に対し, Test アルゴリズムを使用, 検索にヒットした場合に医療データの暗号文を返す仕組みとなっている. 我々の安全性評価により, 暗号化キーワードから検索キーワードの情報が得られるが, そもそも検索者はキーワード暗号文へのアクセスにキーワードそのものを使用することから, 検索可能暗号を利用する意

[*1] https://www.nist.gov/digital-twins
[*2] https://pubmed.ncbi.nlm.nih.gov/
[*3] 医療情報システムの安全管理に関するガイドライン 第 7.0 版（令和 8 年 6 月）(https://www.mhlw.go.jp/stf/shingi/0000516275_00006.html)
[*4] CRYPTREC 暗号技術ガイドライン（高機能暗号）2023 年 3 月 (https://www.cryptrec.go.jp/report/cryptrec-gl-2005-2022.pdf)

© 2026 Information Processing Society of Japan

味がないことが分かる．以上, 我々の安全性評価により本システムの根本的な再設計が必要であると主張する．

Disclaimer．Gao らによる医療情報共有システムを高機能暗号やブロックチェーンを用いて構成する試み自体は尊重した上で, 本論文では具体的な攻撃を示すことにより, Gao らのシステムが十分な安全性を満たしていないことを明らかにした．本論文の目的は, 高機能暗号の適切な利用を促す観点からその問題点を指摘することにあり, Gao らの研究を不当に批判することではない．本方式が発表された IEEE IoT ジャーナルについて, 本論文執筆時点において JCR Q1 ジャーナルであり, インパクトファクターが 8.7 と当該分野としては非常に高く, 一定の影響力がある当該分野トップジャーナルであると考える．そのようなジャーナルに採録された論文においても, IBE や PEKS などの高機能暗号が適切に使用されていないこと, 特に IBE のマスター秘密鍵の共有や, PEKS の意義を損なうブロックチェーンを介した IPFS へのアクセス手法が不適切であると明らかにすることは, 一定の意義があるものと考える．

Remark．Gao らの論文において, 曖昧な個所を何点か検出した．この曖昧な個所をどう解釈するかによって攻撃シナリオに影響するため, 我々の解釈を明確にしておく．

マスター秘密鍵について． 彼らの方式において, $\alpha, y, r \in \mathbb{Z}_p$ に対し, 暗号鍵 $\mathsf{sk}_{\mathsf{enc}} = (g_2^{\alpha}(u_0 \prod u_i^{v_i})^r, g_2^r)$, 検索鍵 $\mathsf{sk}_{\mathsf{search}} = (y, g_2^{\alpha})$ と定義している．ここで患者の ID に対し $v = H(ID)$ であり, v_i は v の i 番目のビットを指す．$\mathsf{PK}_{ID} = g_2^y$, $\mathsf{SK}_{ID} = (\mathsf{sk}_{\mathsf{enc}}, \mathsf{sk}_{\mathsf{search}})$ が患者の公開鍵と秘密鍵となる．$\mathsf{sk}_{\mathsf{enc}}$ は Waters IBE の秘密鍵, g_2^{α} は Waters IBE のマスター秘密鍵であることから, 我々の “他人の医療データが閲覧可能” という主張に繋がる．なお Gao らは方式内では使用しない別の値 $\beta \in \mathbb{Z}_p$ も設定しており, 1 か所のみ $\mathsf{sk}_{\mathsf{search}} = (y, g_2^{\beta})$ と表記している．このことから, 暗号部分は α, 検索部分は β を使用と, 目的によって異なるマスター鍵を使用している可能性は捨てきれない．しかしながら, 検索に係る部分でも α が使用されていること, そもそも g_2^{β} が公開パラメータに含まれており, $\mathsf{sk}_{\mathsf{search}}$ が検索権限の委譲機能を実現するための鍵であることを鑑みると, β を検索用途に使用しているとは考えにくい．そこで本論文では, $\mathsf{sk}_{\mathsf{search}} = (y, g_2^{\beta})$ は $\mathsf{sk}_{\mathsf{search}} = (y, g_2^{\alpha})$ のタイポであると解釈して安全性評価を行った．

送信者鍵とサーバ鍵について． ServerKeyGen アルゴリズムにて $(\mathsf{PK}_S, \mathsf{SK}_S)$ を生成していることから, これらは検索を行うクラウドサーバの公開鍵と秘密鍵であると考えられる．しかし暗号化アルゴリズム内にて “SK_S (sender's private key)” という表記もある．具体的に, キーワード w に対し, 暗号化時に $H(w)^{\mathsf{SK}_S}$ を計算することから, SK_S なしでは暗号文を生成できない．公開鍵検索可能認証暗号 (PAEKS: Public key Authenticated Encryption with Keyword Search) [5] を引用し, 暗号化時に送信者の秘密鍵を利用することで, クラウドサーバが任意のキーワードによる暗号化を防ぎ, 内部者キーワード推測攻撃に耐性を持たせるという記述もあることから, $(\mathsf{PK}_S, \mathsf{SK}_S)$ を送信者鍵と解釈すべきとも考えられる．しかし Test アルゴリズム (検索アルゴリズム) にて, “This algorithm inputs ... and the server's private key SK_S” という記述がある．また, Test アルゴリズム内での PK_S^{δ} の計算において, δ はトラップドア生成時の乱数であり Test アルゴリズム実行者には未知である一方で, g_2^{δ} がトラップドアに含まれていることから, PK_S^{δ} は $(g_2^{\delta})^{\mathsf{SK}_S}$ と計算するのが自然であると考える．加えて, トラップドア生成時にも $H(w)^{\mathsf{SK}_S}$ を計算する箇所があることから, SK_S の使用が必要となる．結果として, 暗号化時に使用する SK_S, トラップドア生成時に使用する SK_S, 検索時に使用する SK_S のいずれかが異なる場合, 検索が不可となる．ここで Gao らの論文内にて “Cloud Server (User's account)” という記述に着目, クラウドサーバに保存された暗号文に対し, 送信者自身が検索を行う場合を想定している, すなわち共通鍵検索可能暗号 (SSE: Seymmetric Searchable Encryption) のように PEKS を使用していると本論文では解釈する．より具体的に, SK_S は送信者鍵と解釈, SK_S を用いてキーワードの暗号化とトラップドアの生成を行う．自身のアカウントに紐ついたクラウドサーバに対し SK_S を共有, クラウドサーバは SK_S を用いて検索を行うと解釈する．検索時に送信者秘密鍵 SK_S を使用することは不自然であると考えられるが, 暗号化時にクラウドサーバ秘密鍵を使用するよりも妥当な設定であると判断した．この解釈に基づいて, 本論文では検索を行うクラウドサーバがトラップドアから検索キーワードの情報を得られることを示す．

2. 準備

本章では, Gao らの医療情報共有システム内で使用している暗号要素技術 (IBE, PEKS) について紹介する．

2.1 IBE

IBE は, 参加者の ID を公開鍵として用いる公開鍵暗号方式の一種である [7]．鍵生成センター (KGC: Key generation Center) がマスター鍵ペア $(\mathsf{mpk}, \mathsf{msk})$ を生成する．ID を持つユーザに対し, 鍵生成センタは msk を用いて秘密鍵を計算する．暗号化時には ID を公開鍵として用いる．Gao らは明示していないが, Waters IBE [9] を使用している．$\mathbb{G}_1, \mathbb{G}_2, \mathbb{G}_T$ を素数位数 p を持つ群, $g_1 \in \mathbb{G}_1$, $g_2 \in \mathbb{G}_2$ を生成元, $e : \mathbb{G} \times \mathbb{G} \to \mathbb{G}_T$ をペアリングとする．KGC

© 2026 Information Processing Society of Japan

は $\alpha \xleftarrow{\$} \mathbb{Z}_p$ を選び, $g_1 = g^\alpha$ を計算, $(g_1, g_1^\alpha, g_2, u_0, \ldots, u_n)$ を mpk, g_2^α を msk とする. ここで n は ID の長さであり, $u_0, \ldots, u_n \in \mathbb{G}_1$ である. 平文 $M \in \mathbb{G}_T$ に対し, 暗号文は $C_1 = M \cdot e(g_1^\alpha, g_2)^t$, $C_2 = g_1^t$, $C_3 = (u_0 \prod_{i=1}^n u_i^{v_i})^t$ と定義される. $t \in \mathbb{Z}_p$ は乱数であり, v_i は $v = H(ID)$ の i 番目のビットである. $\mathsf{msk} = g_2^\alpha$ があれば任意の ID に対する秘密鍵が計算できることから, 任意の暗号文が復号可能となることに注意されたい.

2.2 PEKS

PEKS [1], [2] では, 受信者の公開鍵によりキーワードを暗号化する. 受信者は秘密鍵を用いてトラップドア (検索クエリ) を生成, Test アルゴリズムでは暗号化されたキーワードとトラップドアに紐ついたキーワードとが同じか否かを判定する. PEKS では暗号文からキーワードに関する情報が漏洩しないことを要請する一方, トラップドアからはキーワードの情報は漏洩する (キーワード推測攻撃 (KGA: Keyword Guessing Attacks)). Test アルゴリズムの実行にサーバの秘密鍵を使用することで, サーバ秘密鍵を持たない攻撃者 (外部攻撃者) に対して KGA を防ぐことが考えられる. ただし検索サーバを攻撃者 (内部攻撃者) と想定した場合, 依然 KGA が可能となる. これは受信者の公開鍵を用いれば, 任意のキーワードの暗号化が可能であることに起因する. そこで PAEKS [5] では暗号化時に送信者の秘密鍵を追加で用いることで, 内部攻撃者に対する KGA を防いでいる.

3. Gao らの医療情報共有システム

本章では, Gao らの医療情報共有システムを紹介する. 前述した通り, IBE のマスター公開鍵 mpk, マスター秘密鍵 msk は通常 KGC が生成する. 中央集権的な鍵生成を避けるため, Gao らはブロックチェーンを用いた投票により分散的に鍵を生成, そのログは Auditability の観点からブロックチェーン上に保存するとしている. この分散鍵生成については省略する. $\mathbb{G}_1, \mathbb{G}_2, \mathbb{G}_T$ を素数位数 p を持つ群とし, $g_1 \in \mathbb{G}_1$, $g_2 \in \mathbb{G}_2$ を生成元, $e : \mathbb{G}_1 \times \mathbb{G}_2 \to \mathbb{G}_T$ をペアリングとする. $H : \{0,1\}^* \to \{0,1\}^n$, $H' : \{0,1\}^* \to \mathbb{G}_1$, $H_1 : \{0,1\}^* \to \{0,1\}^\lambda$ を衝突困難ハッシュ関数とする (n は ID 長, λ はセキュリティパラメータ). また $u_0, \ldots, u_n \in \mathbb{G}_1$ とする. Gao らの論文では H' が定義されておらず H が使用されているが, 値域が異なるため本論文では区別して取り扱う.

System Setup: 公開パラメータ $\mathsf{pp} = (\mathbb{G}_1, \mathbb{G}_2, \mathbb{G}_T, e, p, g_1, g_2, g_1^\alpha, u_0, \ldots, u_n)$ を生成する.

患者鍵生成: 患者の ID に対し, $v = H(ID)$ を計算, $r, y \xleftarrow{\$} \mathbb{Z}_p$ を選ぶ. 暗号鍵 $\mathsf{sk}_{\mathsf{enc}} = (g_2^\alpha (u_0 \prod u_i^{v_i})^r, g_2^r)$, 検索鍵 $\mathsf{sk}_{\mathsf{search}} = (y, g_2^\alpha)$, 公開鍵 $\mathsf{pk}_{ID} = g_1^y$ を計算し, 公開鍵 $\mathsf{PK}_{ID} = \mathsf{pk}_{ID}$, 秘密鍵 $\mathsf{SK}_{ID} = (\mathsf{sk}_{\mathsf{enc}}, \mathsf{sk}_{\mathsf{search}})$ を出力する.

送信者鍵生成: Gao らの論文では $\mathsf{ServerKeyGen}$ と記載されているが, 前述した通り送信者 (医療従事者) 鍵生成とし, SK_S をクラウドサーバに共有すると解釈する. $x \xleftarrow{\$} \mathbb{Z}_p$ を選び $(\mathsf{SK}_S, \mathsf{PK}_S) = (x, g_2^x)$ を出力する. なお送信者 (医療従事者) は g_2^α を持つと想定する.

医療従事者 (Doctor): 患者の EHR よりキーワードを抽出する. 各キーワード w に対しラベル $\mathsf{Label}_w = H_1(\mathsf{PK}_{ID} || w)$ を生成, また w の暗号文が保存される IPFS のアドレス集合 $\mathsf{PointerSet}_w = \{\mathsf{Addr}_1, \ldots, \mathsf{Addr}_\ell\}$ も生成, インデックス構造を $\{(\mathsf{Label}_w, \mathsf{PointerSet}_w) | w \in \mathcal{W}\}$ と定義しブロックチェーンに保存する. ここで $\mathcal{W}$ はキーワード空間である. 患者の ID と PK_{ID}, 送信者 (医療従事者) の秘密鍵 SK_S を用いて患者の EHR 情報 M 及び EHR の内容に関連するキーワード w を暗号化, 暗号文 $CT = (C_1, C_2, C_3, C_4, C_5)$ を以下のように計算する.

EHR の暗号化: $t \xleftarrow{\$} \mathbb{Z}_p$ を選び, $C_1 = M \cdot e(g_1^\alpha, g_2)^t$, $C_2 = g_1^t$, $C_3 = (u_0 \prod_{i=1}^n u_i^{v_i})^t$ を計算する. ここで v_i は $v = H(ID)$ の i 番目のビットである.

キーワード暗号化: $k \xleftarrow{\$} \mathbb{Z}_p$ を選び, $C_4 = w \cdot \mathsf{PK}_{ID}^k \cdot H(w)^{\mathsf{SK}_S}$, $C_5 = g_1^k$ を計算する.

CT を IPFS に保存する. トラップドア T_w を以下のように計算する.

トラップドア生成: $\delta \xleftarrow{\$} \mathbb{Z}_p$ を選ぶ. 送信者 (医療従事者) の秘密鍵 SK_S, 患者の公開鍵 PK_{ID} を用いて, $t_1 = e(w \cdot H(w)^{\mathsf{SK}_S}, g_2^\alpha) e(\mathsf{PK}_{ID}, \mathsf{PK}_S^\delta)$, $t_2 = g_2^\delta$ を計算, $T_w = (t_1, t_2)$ を出力する.

患者に医療データのアクセス権をリクエストする際に, T_w と C_4 を送付する (Gao らの論文に記載されていないが, クラウドサーバによる T_{auth} の検証に (t_1, t_2), C_4 を用いるためこのように解釈した). リクエストが承認された後, クラウドサーバにキーワード w を送付する (この時点で検索可能暗号を利用する意味がないとわかる). クラウドサーバより IBE 暗号文を得た後, 復号することで患者の EHR を得る. なお医療従事者であることより, 患者 ID に対する IBE 秘密鍵を所持していると解釈した.

患者 (Patient): 自身の医療データに対するアクセス権付与のための鍵 $\mathsf{sk}_{\mathsf{search}}$ を持つ. $\mathsf{sk}_{\mathsf{search}}$ を用いて委譲トラップドア T_{auth} を生成する. なおトラップドアと命名されているもののキーワードには紐ついていないため, 認証用の値であると解釈する. 医療従事者からのリクエストに対し, T_{auth} を以下のように計算する.

委譲トラップドア生成: $r_1, r_2 \xleftarrow{\$} \mathbb{Z}_p$ を選ぶ. 患者は

© 2026 Information Processing Society of Japan

$\mathsf{sk}_{\mathsf{search}} = (y, g_2^{\alpha})$ を用いて, $t_3 = g_2^{\alpha}\mathsf{PK}_S^{r_1}$, $t_4 = g_2^{r_1}$, $t_5 = g_2^{y\alpha}\mathsf{PK}_S^{r_2}$, $t_5 = g_2^{r_2}$ を計算, $\mathsf{T}_{auth} = (t_3, t_4, t_5, t_6)$ を出力する.

T_{auth}, $T_w = (t_1, t_2)$, C_4 をクラウドサーバに送付する.

クラウドサーバ: 共有済の医療従事者の秘密鍵 SK_S を用いて以下を検証する.

T_{auth} の検証:

- $t_7 = t_3/t_4^{\mathsf{SK}_S}$
- $t_8 = t_5/t_6^{\mathsf{SK}_S}$
- $\tilde{a} = e(\mathsf{PK}_{ID}, t_2^{\mathsf{SK}_S}) \cdot e(c_4, t_7)/t_1$
- $\tilde{b} = e(c_5, t_8)$

を計算し, $\tilde{a} = \tilde{b}$ なら 1 を, そうでないなら 0 を出力する.

上記により, 患者から医療従事者への医療データへのアクセス権付与を確認した上で, 医療従事者からキーワード w を得る. キーワードよりラベルを生成, このラベルとブロックチェーン (スマートコントラクト) に保存されてあるインデックス構造より IPFS のアドレスを得る. IPFS に保存された PEKS 暗号文に対し, トラップドアと SK_S を用いて Test アルゴリズムを実行する. なおすでにラベルによる検索を行っている以上, 意味のないステップであることに注意されたい.

Test アルゴリズム:

- $\tilde{c} = e(c_4, t_7)$
- $\tilde{d} = e(c_5, t_8)$

を計算し, $\tilde{c} \cdot e(\mathsf{PK}_{ID}, \mathsf{PK}_S^{\delta}) = \tilde{d} \cdot e(t_1, g_2^{\alpha})$ なら 1 を, そうでないなら 0 を出力する. なお PK_S^{δ} の計算は $t_2^{\mathsf{SK}_S}$ と解釈できるものの, $t_1 \in \mathbb{G}_T$ にも関わらずペアリングに入力していることから, この式は誤りである.

ブロックチェーン: 医療従事者により作成されたインデックス構造や各プロセスのログを保存する.

4. 提案攻撃

4.1 医療データの漏洩

前述した通り, Wtaers IBE のマスター秘密鍵 $\mathsf{msk} = g_2^{\alpha}$ を $\mathsf{sk}_{\mathsf{search}}$ に含めていることが問題である. なお暗号文を保存している IPFS のアドレスとラベルとのマッチング (インデックス構造) はブロックチェーン上に公開されていること, このラベルの計算には秘密鍵を使用していないこと ($\mathsf{Label}_w = H_1(\mathsf{PK}_{ID}||w)$) より, 任意のエンティティが IPFS 上の暗号文にアクセス可能であることに注意されたい. すなわち, $\mathsf{sk}_{\mathsf{search}}$ を持つ任意のエンティティが EHR を閲覧可能となる. また T_{auth} の検証プロセスにおいて, クラウドサーバは $t_3/t_4^{\mathsf{SK}_S} = g_2^{\alpha}$ を計算している. すなわち, クラウドサーバも医療データを閲覧可能であると言える.

4.2 キーワードの漏洩

前述した通り, Gao らのシステムではラベルを用いて IPFS のアドレスを得た上で PEKS によるキーワード検索を行っていること, ラベルの計算にキーワード自身が必要なこと, クラウドサーバにキーワードそのもの与えていることから, 検索可能暗号を用いる意味がない. しかし IBE と異なり, PEKS 部分を独自に提案していることから, PKES そのものの安全性を評価することは意義があると考える. 以下の攻撃により, システムフローの見直しでは修正できず, PEKS そのものの再設計が必要であると言える. トラップドア $T_w = (t_1, t_2)$ に対し, 以下の式が成り立つ.

$$
\begin{aligned}
&t_1/e(\mathsf{PK}_{ID}, t_2^{\mathsf{SK}_S}) \\
&= e(w \cdot H(w)^{\mathsf{SK}_S}, g_2^{\alpha}) e(\mathsf{PK}_{ID}, \mathsf{PK}_S^{\delta}) / e(\mathsf{PK}_{ID}, t_2^{\mathsf{SK}_S}) \\
&= e(w \cdot H(w)^{\mathsf{SK}_S}, g_2^{\alpha}) \\
&= e(w \cdot H(w)^{\mathsf{SK}_S}, t_3/t_4^{\mathsf{SK}_S})
\end{aligned}
$$

ここで $g_2^{\alpha} = t_3/t_4^{\mathsf{SK}_S}$ の関係性を利用した. SK_S を持つ攻撃者がチャレンジキーワード (w_0^*, w_1^*) を宣言, チャレンジャーは $b \xleftarrow{\$} \{0,1\}$ を選び, $T_w^* = (t_1, t_2)$ を計算, 攻撃者に返す. ここでクラウドサーバは T_{auth} を得られるとすると, (t_3, t_4) も入手可能となる. $t_1/e(\mathsf{PK}_{ID}, t_2^{\mathsf{SK}_S}) = e(w_0^* \cdot H(w_0^*)^{\mathsf{SK}_S}, t_3/t_4^{\mathsf{SK}_S})$ が成り立てば $b = 0$ を, 成り立たない場合は $b = 1$ を出力する.

5. 議論

前述の通り, Gao らによる医療情報共有システムを高機能暗号やブロックチェーンを用いて構成する試み自体は尊重した上で, 本論文では具体的な攻撃を示すことにより, Gao らのシステムが十分な安全性を満たしていないことを明らかにした. 高機能暗号やブロックチェーンを用いた安全な医療情報共有システムの構築に向けて, Gao らのシステムの問題点について議論する.

Gao らのシステムにおける脆弱性のうちシステムフローに関係する部分として, 患者が IBE のマスター秘密鍵を共有していることから他人の医療情報を閲覧可能であること, IPFS のアドレスを得るためにキーワードそのものをクラウドサーバに渡していることから検索可能暗号を利用する必要がないことが挙げられる. まずこれらの問題点について議論する. 暗号方式を利用したセキュアシステムの設計には, 誰がどのような鍵を持つのか, 誰に対して何を守りたいのかを明確に定義するため, 各エンティティの役割を明確化する必要がある. 一方 Gao らの論文では, エンティティが適切に定義されていない. 例えば Doctor, Patients, Cloud Server, Healthcare center, KGC というエンティティ名称の他に, Sender, Requester, Data User, Data Researcher などが定義されている. ここで, 例えば Data User や Data Researcher が誰なのか (Doctor なのか Patients なのか) が

© 2026 Information Processing Society of Japan

適切に定義されていない. また前述の通り, 送信者鍵とサーバ鍵について適切に定義されていない. これらのことから, 上記システムフローに起因する脆弱性の背景として,

“誰に対し何を守りたいのかが不明瞭である”

ことが本質的ではないかと考える. 例えば医療従事者であれば, 自身の患者の医療情報を閲覧することは医療行為上問題ないと考えられる一方, 医療従事者が研究者として他の医療従事者の患者情報を閲覧する際には, 何等かのルールが必要であると考えられる. この際, 自身の患者か否かにより医療情報の閲覧権限をコントロールする仕組みが必要であると考えられる. このような仕組みを実現するために, Gao らは患者による閲覧権限の委譲を検討したものと考えられる. この委譲プロセスにおける直接的な問題点として, 権限移譲されたクラウドサーバが IBE のマスター秘密鍵 g_2^{α} を入手できてしまうこと, さらに委譲プロセスにおいては固定値 g_2^{α} を ElGamal 暗号化 $((t_3 = g_2^{\alpha}\mathsf{PK}_S^{r_1}, t_4 = g_2^{r_1}))$, この暗号文を復号しているに過ぎず, 認証としての安全性を担保していないことが挙げられる. この直接的な問題の背景には, 前述のように各エンティティの役割が不明瞭であることが考えられる. 同様に, Gao らが提案する PEKS が脆弱であること以上に, クラウドサーバにキーワードを直接与える (クラウドサーバには検索キーワードの情報を与えてよい) ことと, クラウドサーバがトラップドアを用いて検索を行うこと (クラウドサーバには検索キーワードの情報を与えたくない) が混在していること, すなわちクラウドサーバに対して何の情報を与えた上で何の役割を担うエンティティなのかを定義していないことが本質的な原因であると考える.

以上の議論により, (1) 医療情報共有システムにおけるエンティティの明確化 (2) 各エンティティに対し, 何を守る必要があるのかの明確化を行った後, 適切な高機能暗号やブロックチェーンなどを用いることが必要であると考える. 例として, ある患者に対し担当の医者と患者本人以外への医療データ閲覧を防ぐ目的であれば, 攻撃者に担当医者と該当患者以外の全ての秘密情報を与える安全性モデルを採用すべきである. 同様に, 検索を行うクラウドサーバを想定攻撃者とし, クラウドサーバに対して検索キーワードの情報を秘匿する目的であれば, 攻撃者にクラウドサーバの秘密鍵を与える安全性モデルを採用すべきである. Gao ら独自設計の PEKS 方式が脆弱であることは, 彼らによる暗号学的な安全性証明の不備であると考えられるが, その安全性証明の前に安全性モデルが不明瞭であることが本質的な原因であると考える. まずは安全性モデルの精緻化を行った上で, 既存の (安全性が証明された) 方式で問題ないのであればそれを使用する, 既存方式で達成できていない安全性や機能が存在する場合, 初めて暗号方式を提案するのが望ましいのではないかと我々は考える. なお Gao らの医療情報共有システムでは, ブロックチェーンを用いた IBE マスター秘密鍵の分散生成や, スマートコントラクトが暗号文のハッシュ値を確認する際に用いているゼロ知識証明など, 本論文では言及しなかった部分においても様々な問題や脆弱性が散見される. 上記議論により, 各手法にパッチを当てるような修正ではなく, エンティティの明確化や安全性モデルの精緻化を含めた本システムの根本的な再設計が必要であると本論文では主張する.

6. 結論

本論文では, Gao らの医療情報共有システムに対する安全性評価を行った. 本論文で指摘した脆弱性の背景として, セキュアシステムにおけるエンティティの明確化, どのエンティティに対し何を守りたいのかの明確化を挙げた. これらを明確にした上で, 必要な高機能暗号やブロックチェーンなどを用いることで, 安全なシステムの設計に資するものと期待する.

謝辞 本研究は JSPS 科研費 JP25H01106 の助成を受けたものです.

参考文献

[1] Michel Abdalla, Mihir Bellare, Dario Catalano, Eike Kiltz, Tadayoshi Kohno, Tanja Lange, John Malone-Lee, Gregory Neven, Pascal Paillier, and Haixia Shi. Searchable encryption revisited: Consistency properties, relation to anonymous IBE, and extensions. *Journal of Cryptology*, 21(3):350–391, 2008.

[2] Dan Boneh, Giovanni Di Crescenzo, Rafail Ostrovsky, and Giuseppe Persiano. Public key encryption with keyword search. In *EUROCRYPT*, pages 506–522, 2004.

[3] Dan Boneh and Matthew K. Franklin. Identity-based encryption from the weil pairing. In *CRYPTO*, pages 213–229, 2001.

[4] Hongmin Gao, Yuhe Zhang, Libo Wang, Zhiquan Liu, and Zhaofeng Ma. A searchable encryption scheme for blockchain-based digital twins. *IEEE Internet Things Journal*, 12(20):42274–42289, 2025.

[5] Qiong Huang and Hongbo Li. An efficient public-key searchable encryption scheme secure against inside keyword guessing attacks. *Information Sciences*, 403:1–14, 2017.

[6] Reinhard C. Laubenbacher, Borna Mehrad, Ilya Shmulevich, and Natalia A. Trayanova. Digital twins in medicine. *Nature Computational Science*, 4(3):184–191, 2024.

[7] Adi Shamir. Identity-based cryptosystems and signature schemes. In *CRYPTO*, volume 196, pages 47–53, 1984.

[8] Alexandre Vallée. Digital twin for healthcare systems. *Frontiers in Digital Health*, 5, 2023.

[9] Brent Waters. Efficient identity-based encryption without random oracles. In *EUROCRYPT*, pages 114–127, 2005.

研究倫理

本論文では, Gao らの医療情報共有システムに対する安全性評価を行い, その脆弱性を明らかとした. 我々の知る限り実システムで使用されているシステムではないこと, また暗号理論における通常の安全性評価の範囲であるとし,

© 2026 Information Processing Society of Japan

研究倫理に反するものではないと考える.

© 2026 Information Processing Society of Japan